



AGENTI AI IN PRODUZIONE

# Gli agenti non si schiantano. Derivano

Il motivo per cui un agente AI smette di funzionare in azienda non è quasi mai «non ha capito». È molto più banale — e molto più prevedibile.



## IL FALLIMENTO TIPICO

# Funziona per due mesi. Poi scade una chiave

Un agente entra in produzione e lavora. Dopo 30-60 giorni un token di accesso scade o viene revocato: le API ruotano le credenziali su cicli di circa novanta giorni.

Un `invalid_grant` di Google o un `INVALID_SESSION_ID` di Salesforce da un refresh token scaduto non si recupera riprovando. La logica di retry non serve a niente.

PERCHÉ NON TE NE ACCORGI

# I fallimenti sono silenziosi

- 1 Il tool restituisce un risultato vuoto e il modello lo legge come «nessun dato», non come errore
- 2 Scritture parziali che corrompono lo stato dei passaggi successivi, senza nessun messaggio d'errore
- 3 Percorsi di recupero inventati dal modello, che somigliano a progresso e non lo sono



## IL PROBLEMA DI INVENTARIO

# Gli **agenti orfani** sono la norma, non l'eccezione

Agenti il cui creatore non è più in azienda — account disattivato — ma le cui credenziali restano attive. È uno dei riscontri più frequenti nelle verifiche degli inventari aziendali del 2026.

**Non è una vulnerabilità esotica: è la conseguenza di non aver mai deciso chi possiede il ciclo di vita di quelle chiavi.**



E QUANDO È OSTILE

# Le catene di strumenti sono la superficie d'attacco

Chiamate a strumenti singolarmente innocue, orchestrate in sequenza, producono un esito malevolo. La ricerca STAC ha misurato tassi di successo oltre il 90% su 483 casi.

Casi reali documentati nel 2025-2026: una RCE nel protocollo MCP (CVE-2025-6514, CVSS 9,6), un'iniezione via hooks in un agente di coding (CVE-2025-59536, CVSS 8,7), un pacchetto malevolo pubblicato come MCP server.



# Il prototipo lo fa l'AI. La produzione è un mestiere

## Parliamone

Team Augmentation Digitiamo: figure senior che progettano rotazione delle credenziali, allarmi sui fallimenti silenziosi, inventario degli agenti e fallback controllato. La parte che nessuna demo mostra.